Task 5 Cybersecurity Lab

This project presents a web application penetration test conducted on DVWA hosted on a Metasploitable environment. The assessment identified critical vulnerabilities including SQL Injection, Cross-Site Scripting (XSS), and Command Injection. These vulnerabilities were successfully exploited to demonstrate potential risks such as unauthorized access and system compromise.

An incident response simulation was also performed to detect and mitigate attacks using log monitoring and firewall rules. The findings emphasize the importance of secure coding, input validation, and continuous monitoring in modern web applications.

Objective:

To identify and exploit vulnerabilities in DVWA and analyze their impact on system security.

Scope:

- Target: DVWA on Metasploitable
- Environment: Virtual lab setup
- Type: Black-box testing
- Attacks performed:
    - SQL Injection
    - XSS
    - Command Injection

Tools Used:

- Kali Linux
- DVWA
- Metasploitable
- Nmap
- Gobuster
- Web Browser

Methodology:

The project was carried out in the following phases:

1. **Reconnaissance** – Identifying open ports using Nmap
2. **Enumeration** – Finding directories using Gobuster
3. **Exploitation** – Performing SQL Injection, XSS, Command Injection
4. **Incident Response** – Detecting and mitigating attacks

PART 1 :Web Application Penetration Testing on DVWA

STEP 1: SETUP DVWA

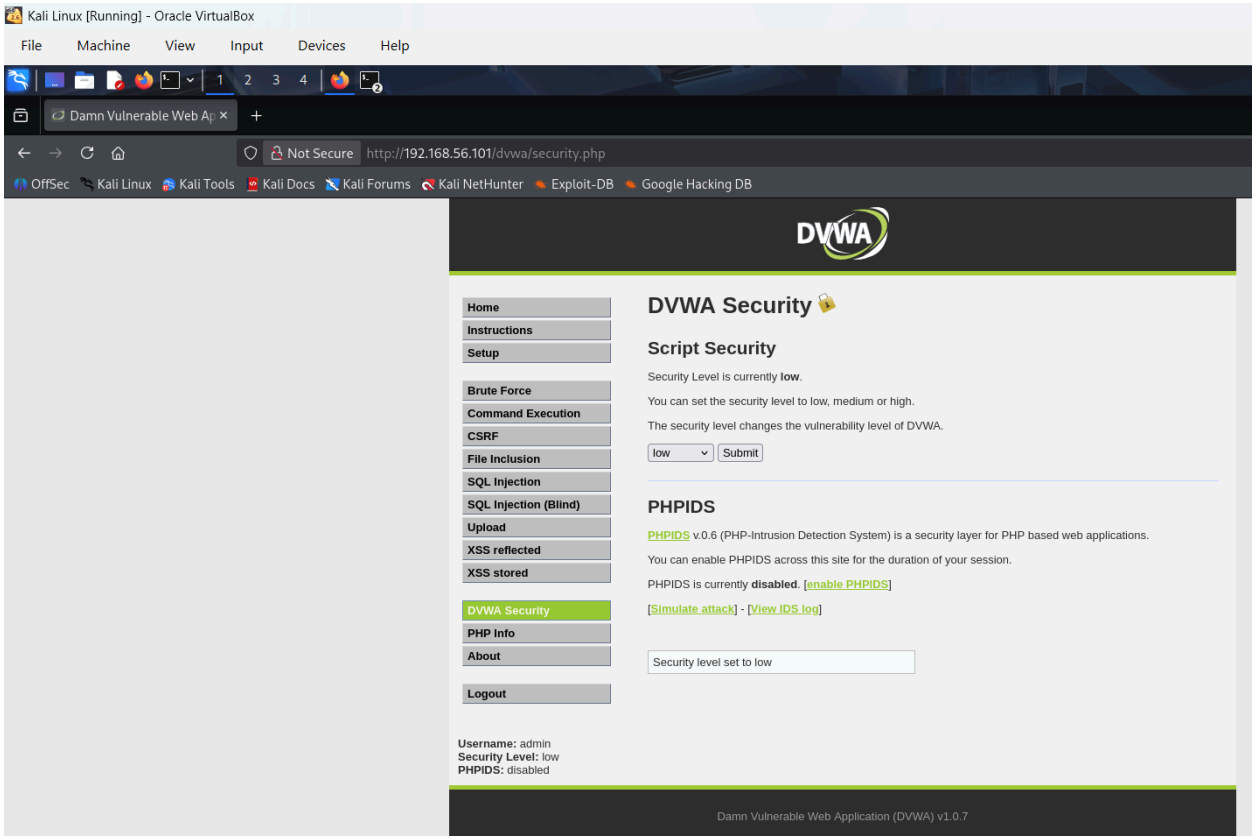


Fig 1 : dvwa_setup.png

STEP 2: RECONNAISSANCE

Kali Linux [Running] - Oracle VirtualBox

File Machine View Input Devices Help

1 2 3 4

Session Actions Edit View Help

```
        TX packets 26  bytes 3276 (3.1 KiB)
        TX errors 0  dropped 0 overruns 0  carrier 0  collisions 0
lo: flags=73<UP,LOOPBACK,RUNNING>  mtu 65536
        inet 127.0.0.1  netmask 255.0.0.0
        inet6 ::1  prefixlen 128  scopeid 0x10<host>
        loop  txqueuelen 1000  (Local Loopback)
        RX packets 8  bytes 480 (480.0 B)
        RX errors 0  dropped 0  overruns 0  frame 0
        TX packets 8  bytes 480 (480.0 B)
        TX errors 0  dropped 0 overruns 0  carrier 0  collisions 0

┌──(kali㉿kali)-[~]
└─$ nmap -sV -A 192.168.56.101
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-25 10:38 EDT
Stats: 0:01:06 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 95.65% done; ETC: 10:40 (0:00:03 remaining)
Nmap scan report for 192.168.56.101
Host is up (0.0011s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
| ftp-syst:
|   STAT:
| FTP server status:
|      Connected to 192.168.56.103
|      Logged in as ftp
|      TYPE: ASCII
|      No session bandwidth limit
|      Session timeout in seconds is 300
|      Control connection is plain text
|      Data connections will be plain text
|      vsFTPd 2.3.4 - secure, fast, stable
|_End of status
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
| ssh-hostkey:
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
```

Fig 2 : `nmap_scan.png`

STEP 3: ENUMERATION

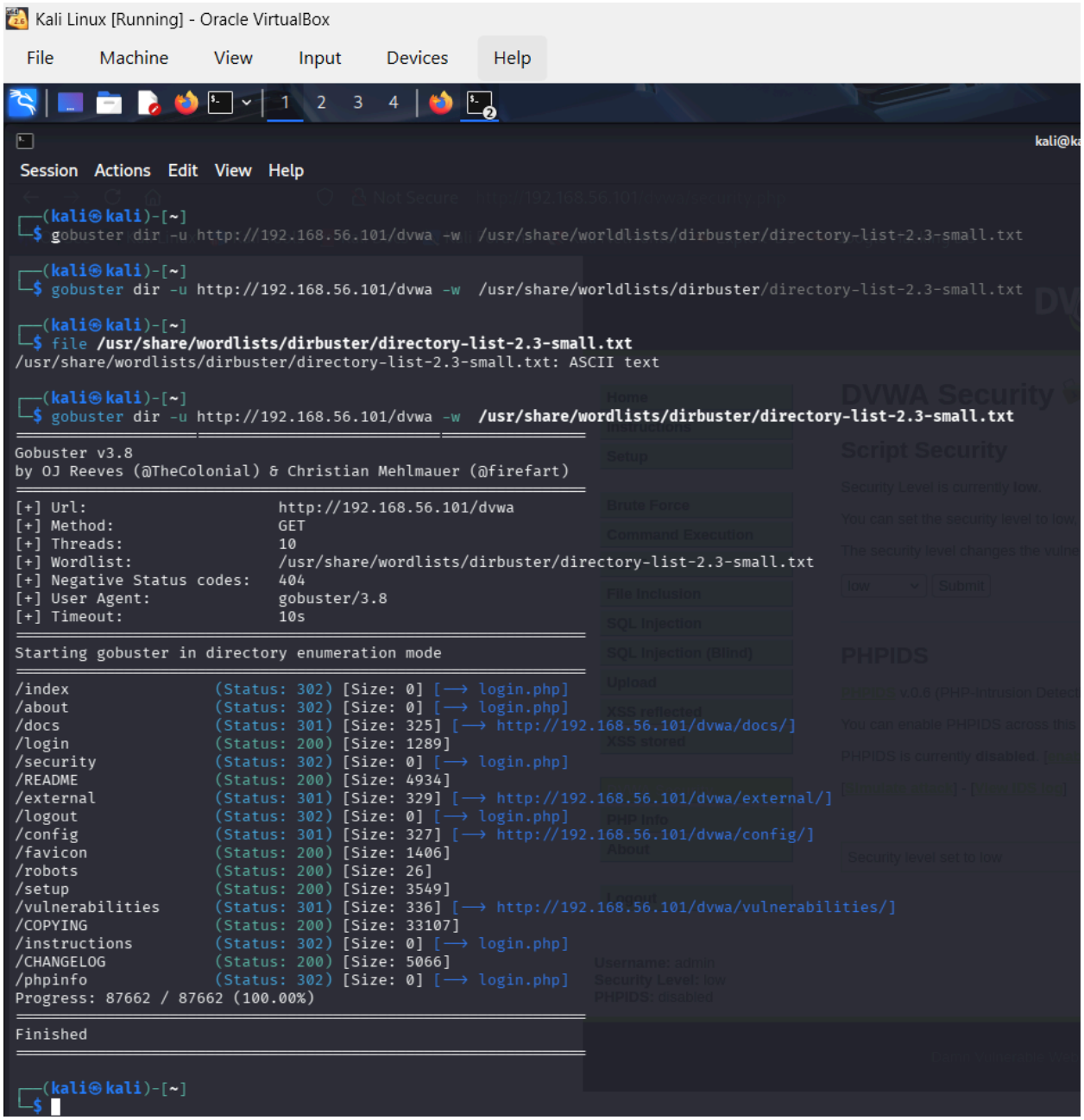


Fig 3 : gobuster.png

STEP 4: EXPLOITATION

1. SQL Injection

DVWA → SQL Injection

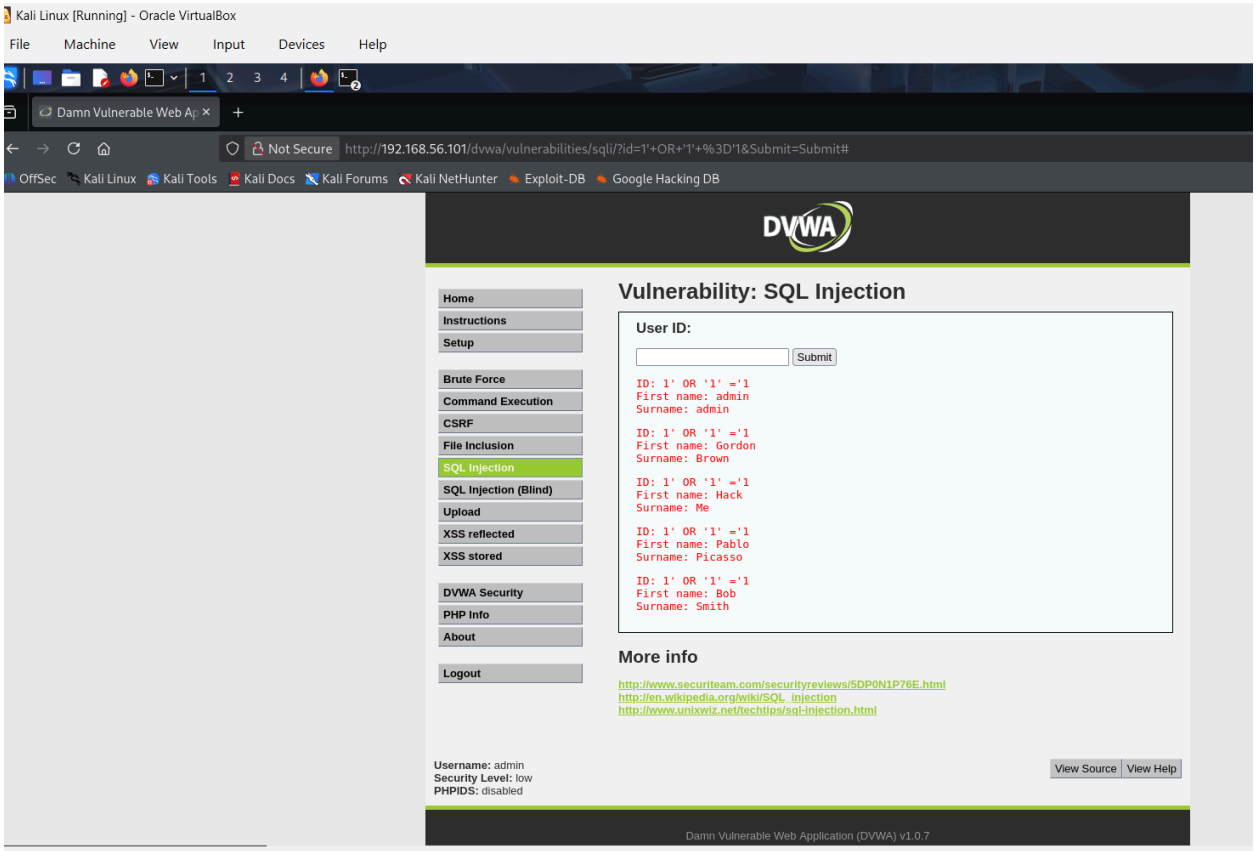


Fig 4 : sql.png

2. XSS Attack

DVWA → XSS (Stored)

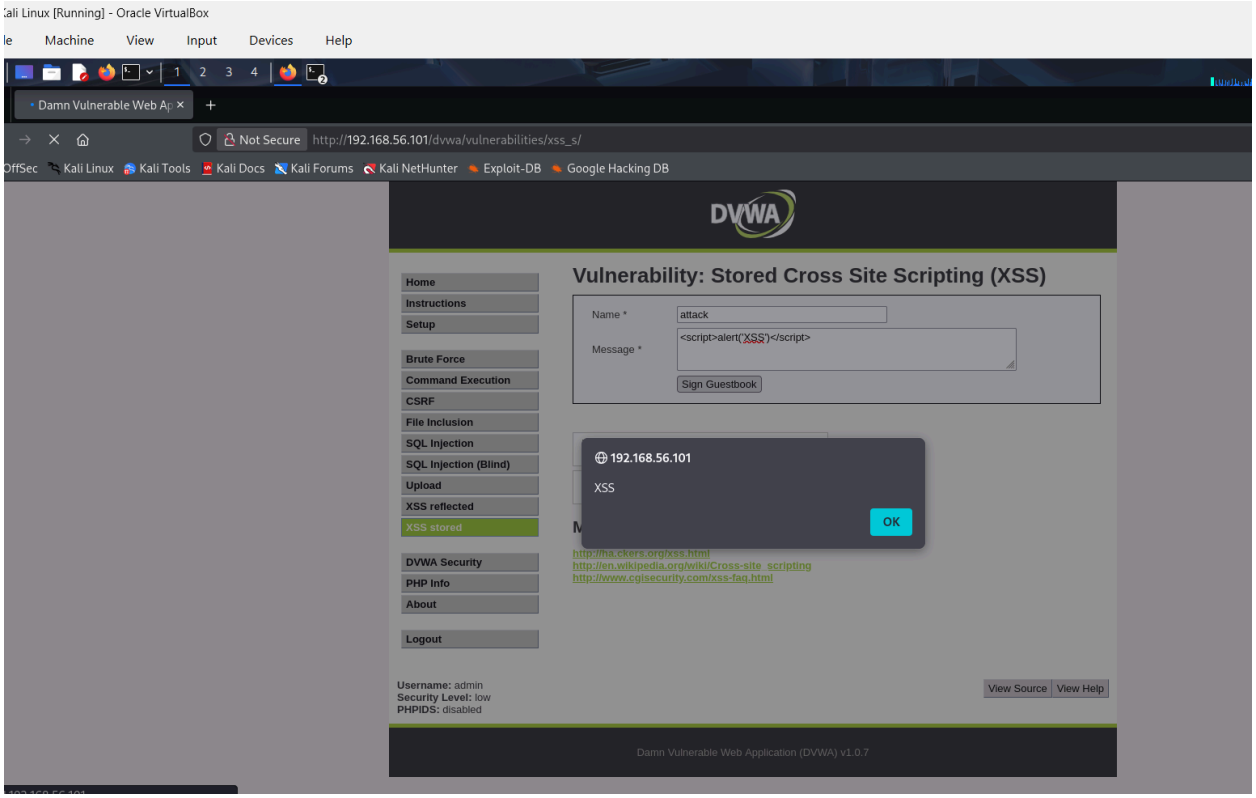


Fig 5 : xss.png

3. Command Injection

DVWA → Command Injection

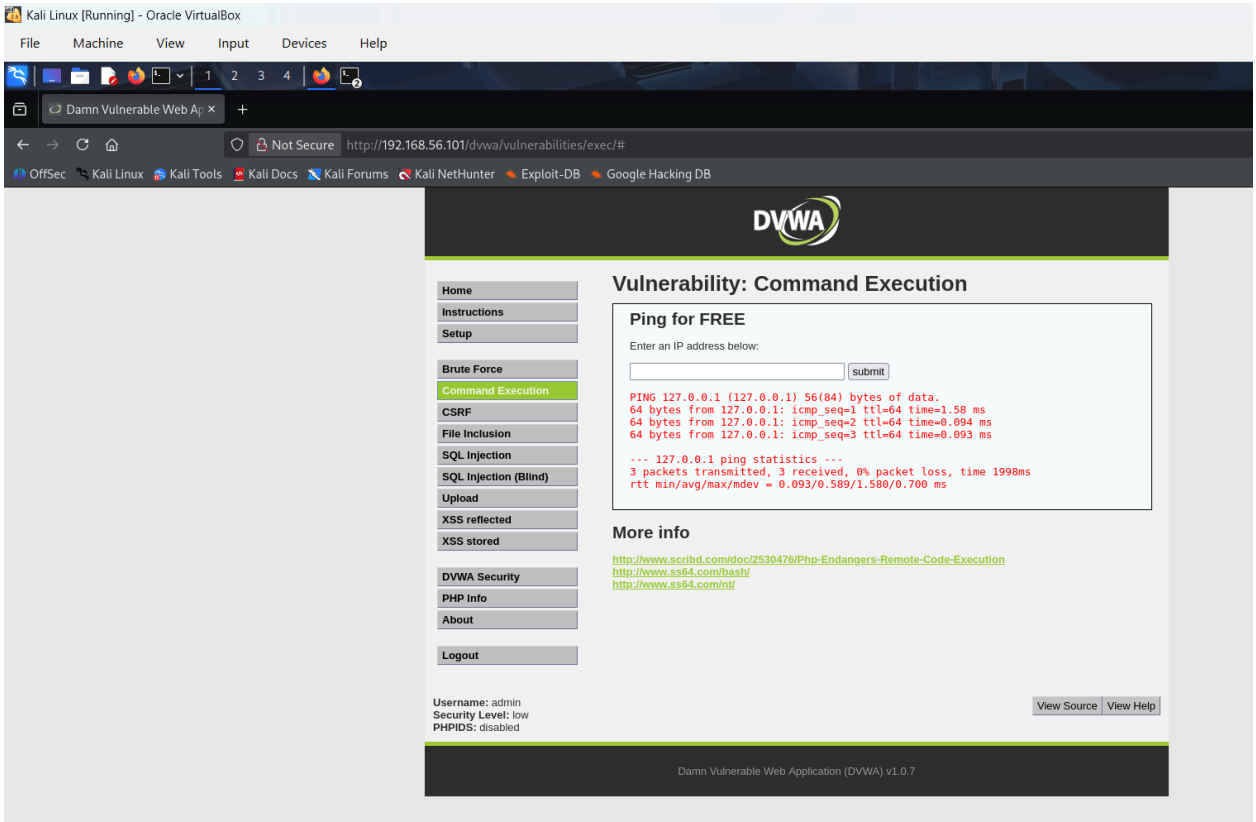


Fig 6 : cmd.png

PART 2: PROJECT PLANNING

PART 2 (A): Objectives, Scope, Tools, Timeline

1. Objective

The objective of this project is to perform a web application penetration test on DVWA (Damn Vulnerable Web Application) to identify security vulnerabilities such as SQL Injection, Cross-Site Scripting (XSS), and Command Injection, and to analyze their impact on system security.

2. Scope

- Target System: DVWA running on Metasploitable
- Environment: Controlled virtual lab (Kali Linux as attacker)
- Type of Testing: Black-box testing
- Vulnerabilities Covered:
    - SQL Injection
    - Cross-Site Scripting (XSS)
    - Command Injection

3. Tools Used

- Kali Linux
- DVWA (Damn Vulnerable Web Application)
- Nmap (for reconnaissance)
- Gobuster (for directory enumeration)
- Web Browser (for manual testing)

4. Timeline

Phase	Activity	Duration
1	Environment Setup	Day 1
2	Reconnaissance (Nmap Scan)	Day 2
3	Enumeration (Gobuster)	Day 2
4	Exploitation (SQLi, XSS, Command Injection)	Day 3
5	Report Writing & Documentation	Day 4

PART 2 (B): Network Diagram

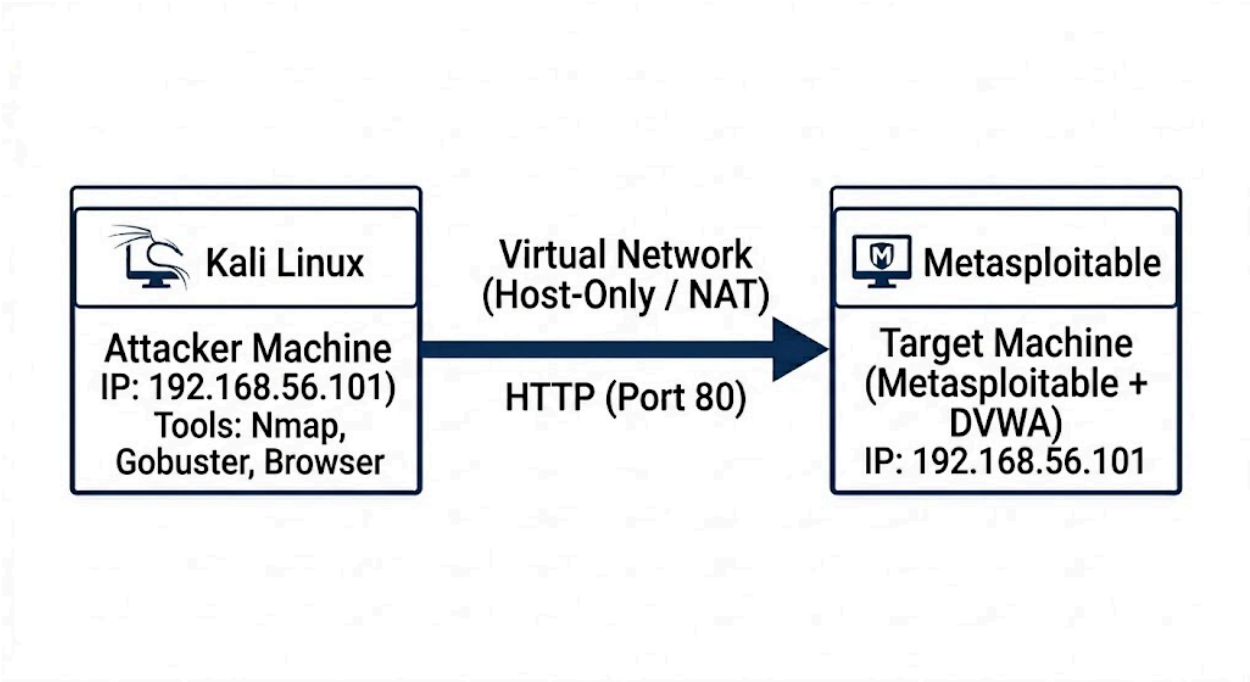


Fig 7.1 : Netwrok Diagram 1

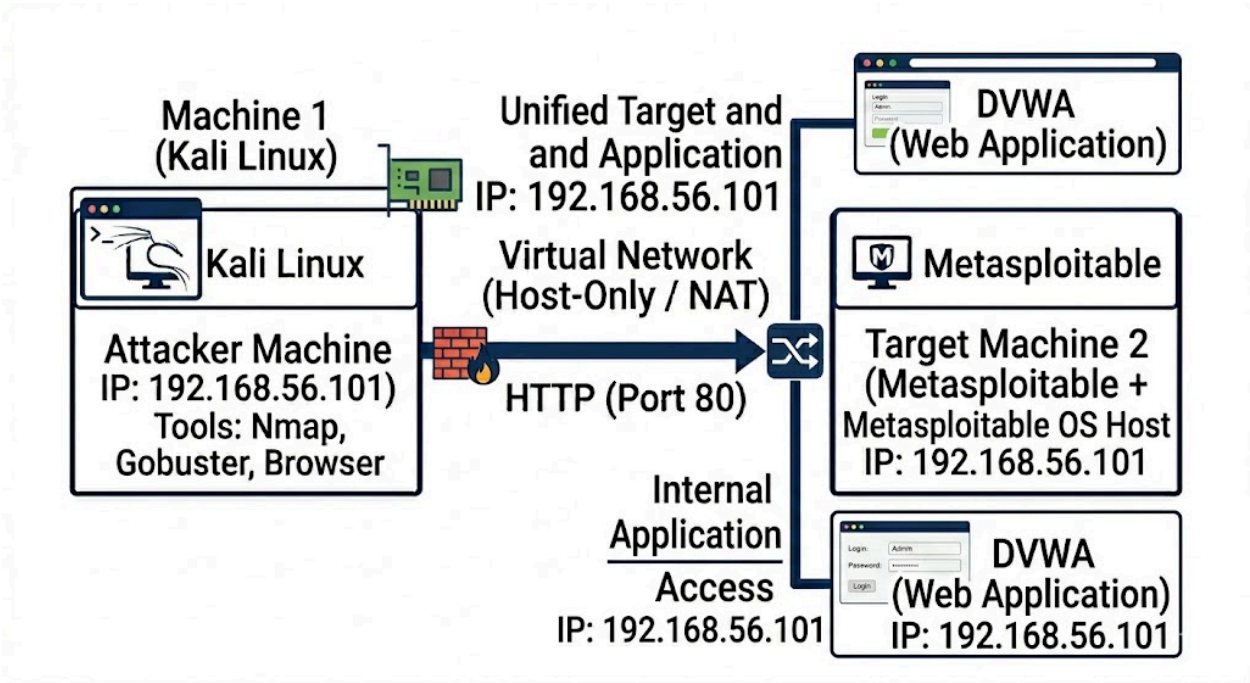


Fig 7.2 : Netwrok Diagram 2

The network diagram illustrates a penetration testing lab where the attacker machine (Kali Linux) communicates with the target system (Metasploitable running DVWA) over a virtual network. Various tools such as Nmap and Gobuster are used to identify and exploit vulnerabilities in the web application.

PART 3: Implementation

STEP 1: RECON + SCANNING + EXPLOITATION

3.1 Reconnaissance & Scanning

Reconnaissance is the initial phase of penetration testing used to gather information about the target system.

An Nmap scan was performed to identify open ports and services running on the target machine.

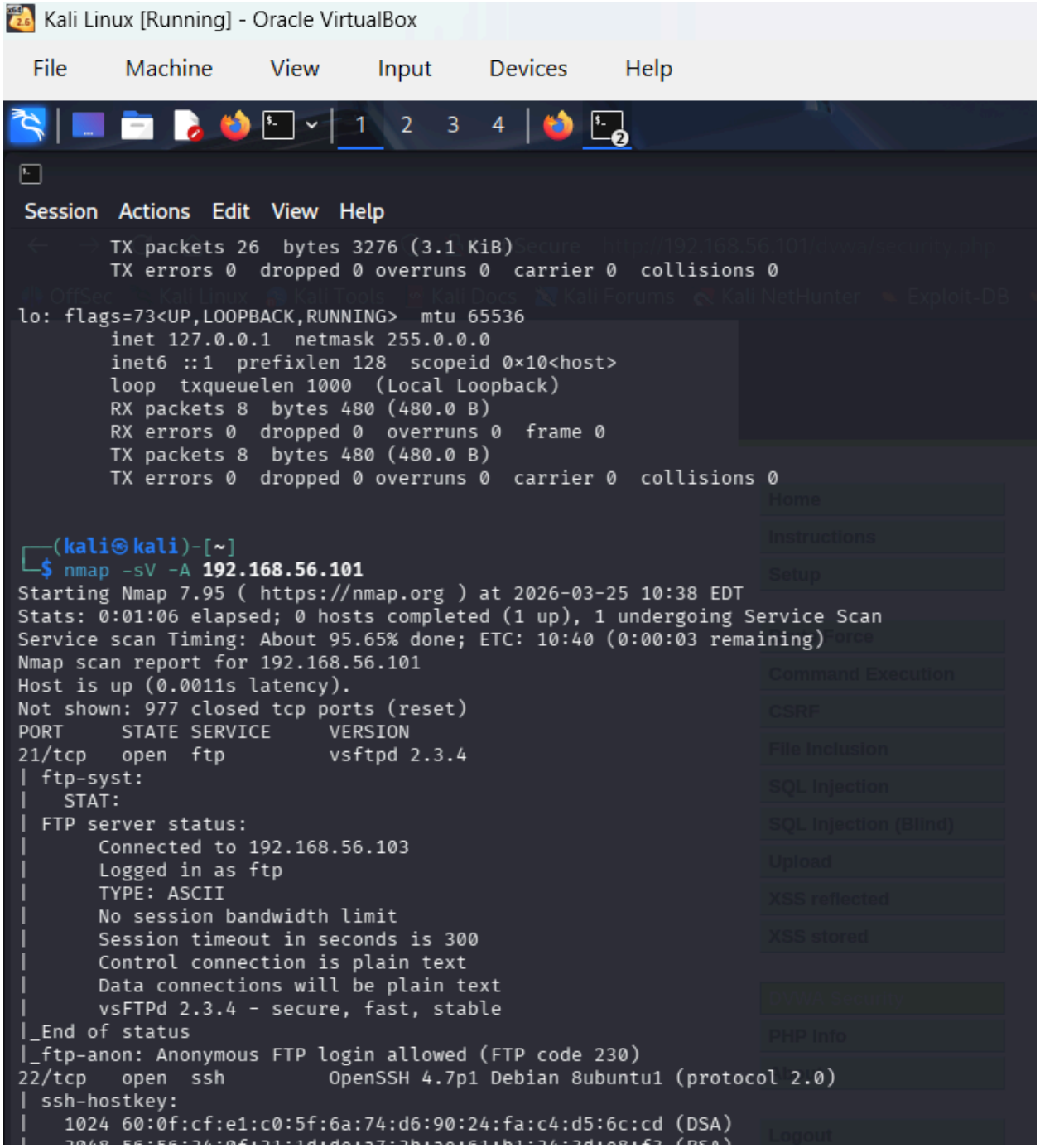


Fig 8 : nmap Scanning

3.2 Enumeration

Directory enumeration was performed using Gobuster to discover hidden directories.

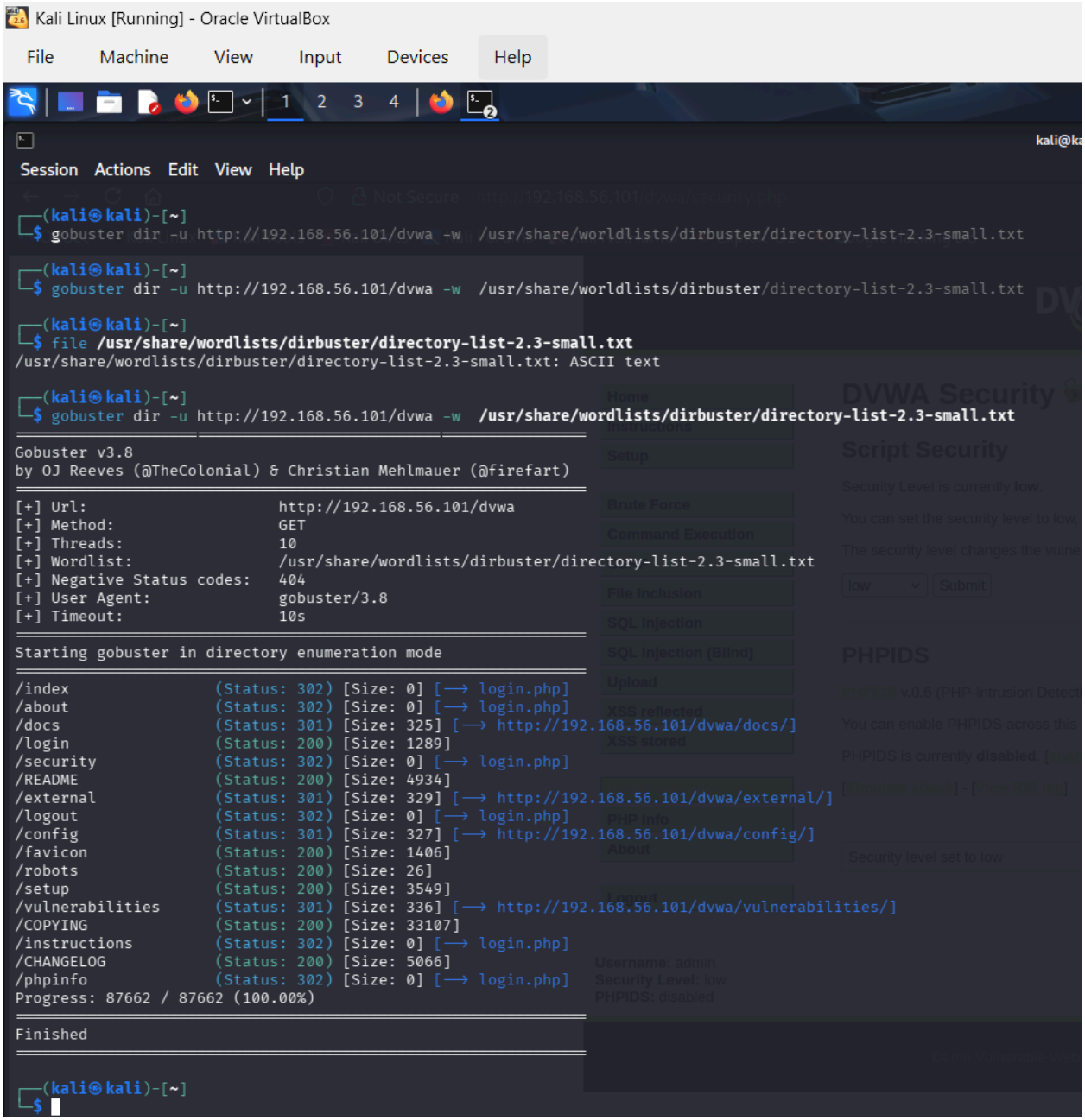


Fig 9 : Enumeration Testing

3.3 Exploitation

1. SQL Injection

SQL Injection was performed on the DVWA SQL Injection module.

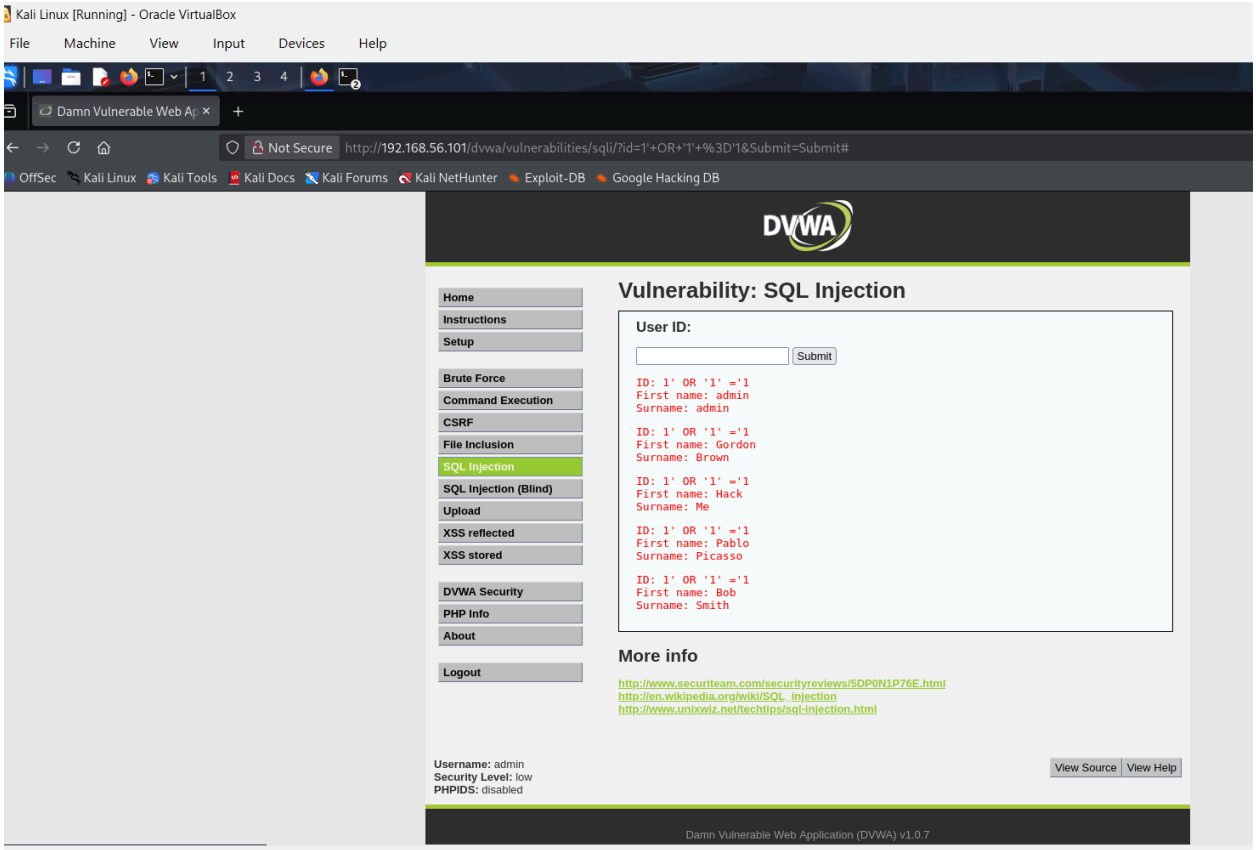


Fig 10 : SQL Injection

Result:

- Retrieved multiple user records
- Authentication bypass achieved

2. Cross-Site Scripting (XSS)

XSS attack was performed using a script injection.

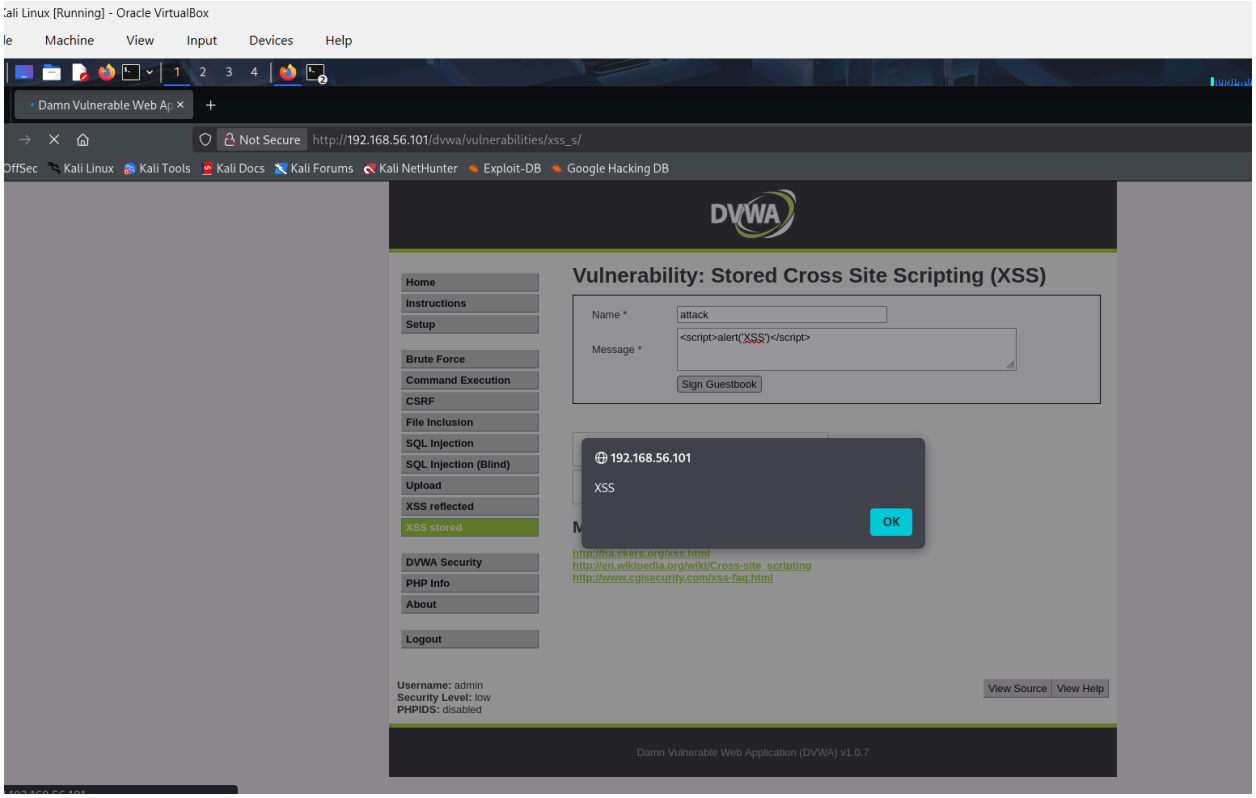


Fig 11 : XSS Attack

Result:

- JavaScript executed successfully
- Alert popup displayed

3. Command Injection

Command Injection was performed in DVWA.

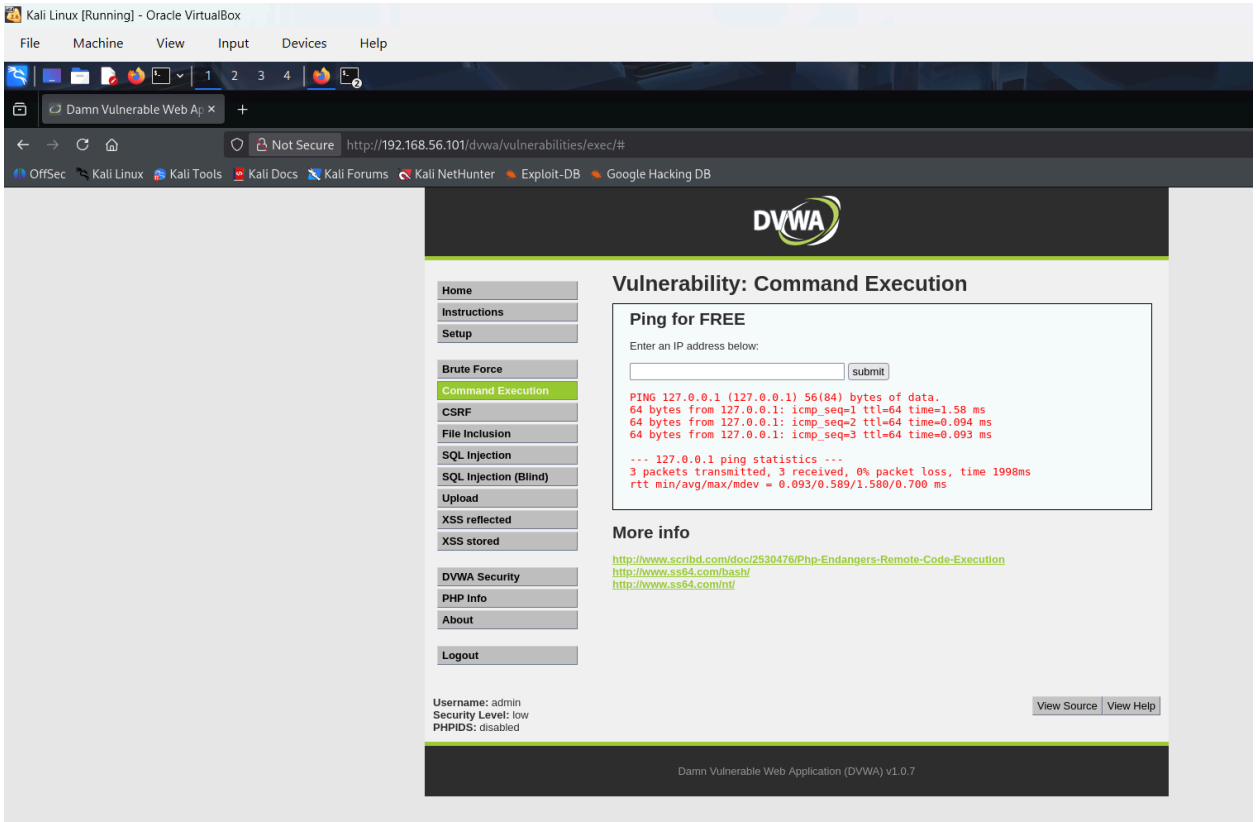


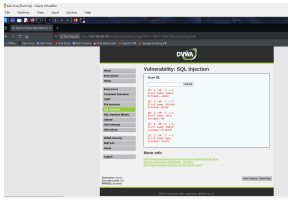
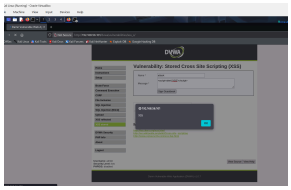
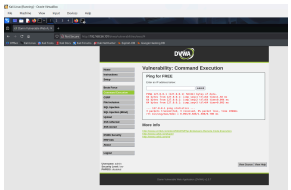
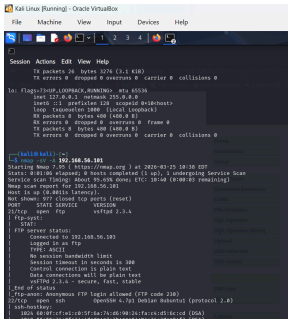
Fig 12 : Command Injection

Result:

- System command executed
- Directory listing obtained

STEP 2: DOCUMENT FINDINGS WITH EVIDENCE

3.4 Findings with Evidence

Vulnerability	Description	Evidence	Severity
SQL Injection	Bypassed authentication using SQL payload		High
XSS	Executed malicious JavaScript		Medium
Command Injection	Executed system commands		Critical
Open Ports	Multiple services exposed		Medium

STEP 3: MITIGATION STRATEGIES

3.5 Mitigation Strategies

To prevent the identified vulnerabilities, the following measures are recommended:

- **For SQL Injection**:
  - Use prepared statements and parameterized queries
  - Validate and sanitize user input
- **For XSS:**
  - Escape output data
  - Use Content Security Policy (CSP)
  - Validate input fields
- **For Command Injection:**
  - Avoid direct system command execution
  - Use secure APIs instead of system calls
  - Validate inputs strictly
- **General Security Measures:**
  - Use firewall protection
  - Disable unnecessary services
  - Regular security testing and updates

PART 4: Incident Response Simulation

STEP 1: DETECT ATTACK IN LOGS

```
s/ HTTP/1.1" 200 5251 "http://192.168.56.101/dvwa/vulnerabilities/xss_s/" "Mozil
la/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0"
192.168.56.103 - - [25/Mar/2026:12:21:49 -0400] "GET /dvwa/vulnerabilities/sqli/
 HTTP/1.1" 200 4333 "http://192.168.56.101/dvwa/vulnerabilities/xss_s/" "Mozilla
/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0"
192.168.56.103 - - [25/Mar/2026:12:21:58 -0400] "GET /dvwa/vulnerabilities/sqli/
?id=1%27+OR+%271%27%3D%271&Submit=Submit HTTP/1.1" 200 4660 "http://192.168.56.1
01/dvwa/vulnerabilities/sqli/" "Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/
20100101 Firefox/140.0"
192.168.56.103 - - [25/Mar/2026:12:22:02 -0400] "GET /dvwa/vulnerabilities/sqli/
?id=1%27+OR+%271%27%3D%271&Submit=Submit HTTP/1.1" 200 4660 "http://192.168.56.1
01/dvwa/vulnerabilities/sqli/" "Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/
20100101 Firefox/140.0"
192.168.56.103 - - [25/Mar/2026:12:24:35 -0400] "GET /dvwa/security.php HTTP/1.1
" 200 4104 "http://192.168.56.101/dvwa/vulnerabilities/sqli/?id=1%27+OR+%271%27%
3D%271&Submit=Submit" "Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101
Firefox/140.0"
192.168.56.103 - - [25/Mar/2026:12:24:38 -0400] "GET /dvwa/vulnerabilities/sqli/
 HTTP/1.1" 200 4333 "http://192.168.56.101/dvwa/security.php" "Mozilla/5.0 (X11;
 Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0"
192.168.56.103 - - [25/Mar/2026:12:24:44 -0400] "GET /dvwa/vulnerabilities/sqli/
?id=1%27+OR+%271%27+%3D%271&Submit=Submit HTTP/1.1" 200 4665 "http://192.168.56.
101/dvwa/vulnerabilities/sqli/" "Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko
/20100101 Firefox/140.0"
```

Fig 13 : incident_logs.png

Attack Detection

The attack was detected by monitoring Apache access logs on the target machine. Suspicious requests containing encoded SQL injection payloads such as `1' OR '1'='1` were observed. The payload appeared in encoded form (`%27 OR %271%27=%271`), confirming that an SQL injection attack was successfully executed and logged.

STEP 2: CONTAIN & ERADICATE

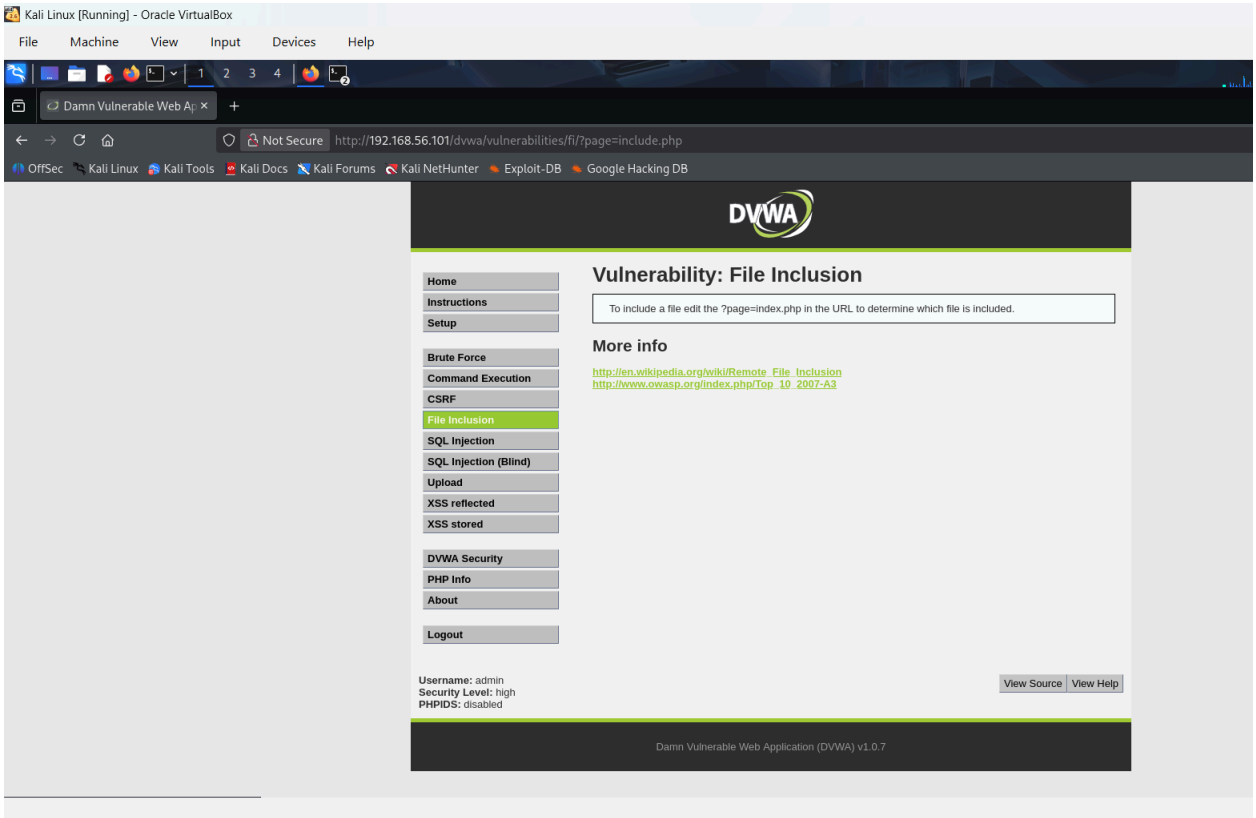


Fig 14 : containment.png

Containment & Eradication

The attack was contained by blocking the attacker's IP address using firewall rules. This prevented further malicious requests from reaching the server. Additionally, vulnerabilities were mitigated by improving input validation and increasing application security settings.

STEP 3: POST INCIDENT REPORT

1. Incident Summary

A simulated cyber attack was performed on the DVWA (Damn Vulnerable Web Application) hosted on the Metasploitable machine. The attack involved exploiting vulnerabilities such as SQL Injection. The attack was successfully executed from the attacker machine (Kali Linux) and detected through server logs.

2. Incident Details

- **Date of Incident:** (Write today's date)
- **Attacker IP Address:** 192.168.56.103 *(or your Kali IP)*
- **Target System:** Metasploitable (DVWA)
- **Attack Type:** SQL Injection

3. Impact Analysis

The attack demonstrated the following risks:

- Unauthorized access to database records
- Exposure of sensitive user information
- Weak input validation mechanisms
- Potential system compromise

4. Detection Method

The attack was detected by monitoring Apache access logs using the `tail -f` command. Suspicious requests containing encoded SQL injection payloads were observed in the logs, confirming malicious activity.

5. Response Actions Taken

- Monitored logs to identify malicious requests
- Identified attacker IP address
- Blocked attacker IP using firewall (iptables)
- Verified that further access was restricted

6. Containment & Eradication

The attack was successfully contained by blocking the attacker's IP address. Vulnerabilities were addressed by improving input validation and adjusting security settings in the application.

7. Lessons Learned

- Importance of continuous log monitoring
- Need for strong input validation
- Early detection helps prevent major damage
- Security testing is essential for web applications

8. Recommendations

- Implement Web Application Firewall (WAF)
- Use prepared statements for database queries

- Regular security audits and penetration testing
- Enable logging and monitoring systems

```
s/ HTTP/1.1" 200 5251 "http://192.168.56.101/dvwa/vulnerabilities/xss_s/" "Mozil
la/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0"
192.168.56.103 - - [25/Mar/2026:12:21:49 -0400] "GET /dvwa/vulnerabilities/sqli/
 HTTP/1.1" 200 4333 "http://192.168.56.101/dvwa/vulnerabilities/xss_s/" "Mozilla
/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0"
192.168.56.103 - - [25/Mar/2026:12:21:58 -0400] "GET /dvwa/vulnerabilities/sqli/
?id=1%27+OR+%271%27%3D%271&Submit=Submit HTTP/1.1" 200 4660 "http://192.168.56.1
01/dvwa/vulnerabilities/sqli/" "Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/
20100101 Firefox/140.0"
192.168.56.103 - - [25/Mar/2026:12:22:02 -0400] "GET /dvwa/vulnerabilities/sqli/
?id=1%27+OR+%271%27%3D%271&Submit=Submit HTTP/1.1" 200 4660 "http://192.168.56.1
01/dvwa/vulnerabilities/sqli/" "Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/
20100101 Firefox/140.0"
192.168.56.103 - - [25/Mar/2026:12:24:35 -0400] "GET /dvwa/security.php HTTP/1.1
" 200 4104 "http://192.168.56.101/dvwa/vulnerabilities/sqli/?id=1%27+OR+%271%27%
3D%271&Submit=Submit" "Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101
Firefox/140.0"
192.168.56.103 - - [25/Mar/2026:12:24:38 -0400] "GET /dvwa/vulnerabilities/sqli/
 HTTP/1.1" 200 4333 "http://192.168.56.101/dvwa/security.php" "Mozilla/5.0 (X11;
 Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0"
192.168.56.103 - - [25/Mar/2026:12:24:44 -0400] "GET /dvwa/vulnerabilities/sqli/
?id=1%27+OR+%271%27+%3D%271&Submit=Submit HTTP/1.1" 200 4665 "http://192.168.56.
101/dvwa/vulnerabilities/sqli/" "Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko
/20100101 Firefox/140.0"
```

Fig 15 : incident_logs.png

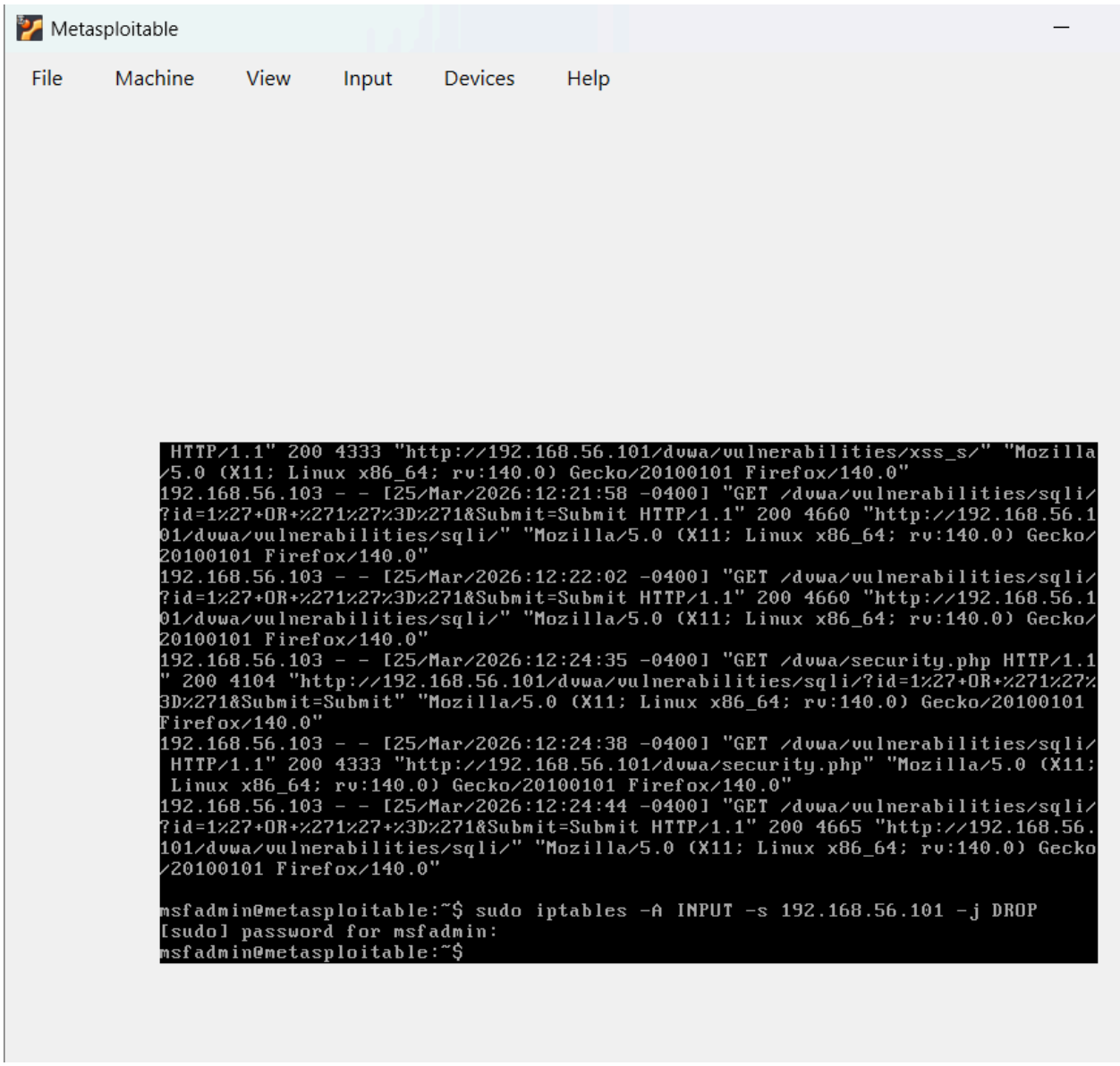


Fig 16 : containment.png

CONCLUSION

This project demonstrated how web application vulnerabilities can be exploited and how proper security measures can mitigate risks. It highlights the importance of secure coding and monitoring systems in preventing cyber attacks.